STRIDE Threat Model Analysis Report

Student name: Innocent Utu
Date: 4/7/2026

1. System Overview and Scope

Description of the System/Application:
AutoDrive Manufacturing operates a cloud-based platform (hosted on AWS) that supports connected and autonomous vehicle technology. The platform manages vehicle telemetry, remote diagnostics, and over-the-air (OTA) firmware updates to maintain vehicle safety and performance. Because the system directly affects physical vehicle operation, a security failure can have safety consequences, not just data-privacy ones, which is why AutoDrive aligns with ISO/SAE 21434.

Key Components in Scope:

- Vehicle Authentication System
- Vehicle Telemetry and Data Management
- Over-the-Air (OTA) Software Update System
- Secure Messaging and Communication System
- Third-Party API for partner/service center integration

Scope of Analysis:
☒ Entire system analyzed

2. System Components Breakdown

Component	Description
Vehicle Authentication System	Vehicles authenticate via digital certificates and secure key exchange; personnel use MFA for remote diagnostics access; fleet users have a password-reset process
Vehicle Telemetry and Data Management	Collects engine diagnostics, location, and performance data continuously; encrypted at rest (AES-256) and in transit (TLS 1.2/1.3); access limited to authorized engineers/fleet managers
OTA Software Update System	Deploys firmware updates remotely; validates firmware integrity via cryptographic signatures; supports rollback on failure
Secure Messaging and Communication System	Carries software updates, emergency alerts, and security warnings between vehicles and cloud; encrypted; monitors for anomalous message patterns

Third-Party API	Allows authorized partners/service centers to access diagnostics, retrieve logs, and request updates; secured with OAuth, API keys, and rate limiting

3. STRIDE Threat Identification

Component	STRIDE Category	Threat Description
Vehicle Authentication System	Spoofing	An attacker forges vehicle certificates or intercepts key exchange to impersonate a legitimate vehicle to the cloud platform
Vehicle Authentication System	Spoofing	Credential stuffing against the fleet manager password-reset process to impersonate an authorized user
OTA Software Update System	Tampering	A compromised or bypassed signature check allows tampered firmware to be installed on a vehicle
Vehicle Telemetry and Data Management	Tampering	Telemetry data is modified in transit or storage to mask a vehicle fault or falsify diagnostic history
Third-Party API	Repudiation	A partner denies having requested a firmware update or accessed diagnostic logs due to insufficient audit logging
OTA Software Update System	Repudiation	Lack of non-repudiable logging allows an internal user to deny initiating an unauthorized firmware push
Third-Party API	Information Disclosure	API misconfiguration exposes sensitive vehicle telemetry data to unauthorized parties
Secure Messaging and Communication System	Information Disclosure	Interception of vehicle-to-cloud messages if TLS is misconfigured or downgraded
Vehicle Authentication System	Denial of Service	Traffic flooding against the authentication service disrupts vehicle connectivity
Third-Party API	Denial of Service	Abusive or malformed API traffic overwhelms backend resources, degrading service for legitimate partners

Third-Party API	Elevation of Privilege	A compromised low-privilege API key is used to access functions or data beyond its intended scope
Vehicle Authentication System	Elevation of Privilege	An attacker with vehicle-level access pivots to broader fleet-management privileges due to weak role segmentation

4. Risk Assessment and Impact

Threat	STRIDE Category	Likelihood	Impact	Overall Risk Level
Forged vehicle certificates / credential stuffing	Spoofing	High	High	Critical
Firmware tampering during OTA delivery	Tampering	Medium	High	High
Telemetry data modification	Tampering	Low	Medium	Medium
Repudiation of update requests/log access	Repudiation	Low	Medium	Medium
API misconfiguration exposing telemetry data	Information Disclosure	Medium	High	High
Message interception via TLS misconfiguration	Information Disclosure	Low	Medium	Medium
DoS on authentication service	Denial of Service	High	Medium	High
API abuse/traffic overload	Denial of Service	Medium	Medium	Medium
API key privilege escalation	Elevation of Privilege	Medium	High	High
Fleet-management privilege pivot	Elevation of Privilege	Low	High	Medium

5. Mitigation Strategies

Threat	STRIDE Category	Mitigation Strategy

Forged vehicle certificates / credential stuffing	Spoofing	Enforce mutual TLS with short-lived certificates; extend MFA to all fleet-service accounts; add rate limiting and anomaly alerts on repeated login/reset failures
Firmware tampering during OTA delivery	Tampering	Use hardware-backed signing keys (HSM) for firmware; enforce mandatory signature and hash verification before install
Telemetry data modification	Tampering	Apply cryptographic checksums/integrity checks on telemetry data at rest and in transit
Repudiation of update requests/log access	Repudiation	Implement centralized, tamper-evident (write-once) audit logging tied to authenticated identities for all update requests and log access
API misconfiguration exposing telemetry data	Information Disclosure	Conduct regular API configuration audits; enforce least-privilege data scoping per API key/role
Message interception via TLS misconfiguration	Information Disclosure	Enforce TLS 1.3 with strict cipher suites; monitor for protocol downgrade attempts
DoS on authentication service	Denial of Service	Deploy DDoS protection at the AWS edge (e.g., AWS Shield); apply rate limiting to authentication endpoints; use autoscaling with circuit breakers
API abuse/traffic overload	Denial of Service	Extend existing API rate limiting; add anomaly-based traffic monitoring
API key privilege escalation	Elevation of Privilege	Enforce strict RBAC scoped to specific API actions; conduct regular privilege reviews
Fleet-management privilege pivot	Elevation of Privilege	Apply network segmentation between vehicle access, telemetry database, and fleet-management systems

6. Summary and Recommendations

Top Three Most Critical Threats

1. **Forged vehicle certificates / credential stuffing (Spoofing)** – Rated Critical because AutoDrive has already observed unauthorized access attempts, and successful spoofing could grant an attacker fleet-wide access to vehicle systems.

2. **Firmware tampering during OTA delivery (Tampering)** – High risk because a compromised update pipeline could push malicious firmware to vehicles, directly threatening physical safety, and firmware mismatches have already been detected.
3. **API misconfiguration exposing telemetry data (Information Disclosure)** – High risk because it has already been flagged as a live concern and could expose sensitive location and diagnostic data to unauthorized parties.

Final Recommendations for Improving Security

AutoDrive should prioritize hardening authentication (extending MFA, enforcing mutual TLS, and monitoring for credential stuffing) and the OTA signing pipeline (HSM-backed keys, mandatory signature verification) as these threats carry safety-level consequences. In parallel, a full audit of API configurations and access scoping will close the data-leakage gap. Finally, implementing tamper-evident logging across all update and API activity will address the repudiation gap and support ISO/SAE 21434 compliance going forward.
